

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check 11.x + Gripe 0.114) · Generated 2026-06-22 · Source: `pom.xml`
· SHA: `61ed8c3`

Summary — Pre-Remediation (Stage 1 findings)

Metric	Count
Total CVEs found	67
CRITICAL CVEs	16
HIGH CVEs	37
MEDIUM CVEs	13
LOW CVEs	1
Outdated dependencies	7
License violations	1 (GPL-2.0)
Supply-chain alerts	2

Summary — Post-Remediation (Stage 3 verified)

Metric	Count
Remaining CVEs	3
CRITICAL CVEs	0
HIGH CVEs	1
MEDIUM CVEs	1
LOW CVEs	1
CVEs cleared by this PR	64

Pre-Remediation: Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix applied
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	✅ → 2.25.4
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2021-44228	10.0	CRITICAL	✅ → 2.25.4
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	✅ → 2.14.0
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	⚠️ MAJOR_REVIEW (fix requires 32.x)
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	⚠️ MAJOR_REVIEW + GPL-2.0 license

commons-io:commons-io	2.4	CVE-2021-29425	4.8	LOW	✓ → 2.14.0
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	✓ → 3.20.0

Pre-Remediation: Top CVEs

CVE	Dependency	CVSS	Severity	Status
CVE-2021-44228	log4j-core / log4j-api	10.0	CRITICAL	✓ Cleared
CVE-2021-45046	log4j-core	9.0	CRITICAL	✓ Cleared
CVE-2019-14379	jackson-databind	9.8	CRITICAL	✓ Cleared
CVE-2019-14540	jackson-databind	9.8	CRITICAL	✓ Cleared
CVE-2020-36518	jackson-databind	7.5	HIGH	✓ Cleared
CVE-2022-42003	jackson-databind	7.5	HIGH	✓ Cleared
CVE-2023-22102	mysql-connector-java	8.3	HIGH	⚠ MAJOR_REVIEW
CVE-2024-7254	protobuf-java (transitive)	7.5	HIGH	✓ Cleared (pinned 3.25.5)
CVE-2021-29425	commons-io	4.8	LOW	✓ Cleared
CVE-2025-48924	commons-lang3	5.3	MEDIUM	✓ Cleared

Supply-chain alerts

CRITICAL — Typosquatted dependency removed. `com.fastxml.jackson.core:jackson-databind:2.9.8` was impersonating the legitimate `com.fasterxml.jackson.core`. Coordinate removed from `pom.xml` in this PR.

HIGH — Untrusted HTTP repository removed. `http://insecure-mirror.example.net/maven2` (plain-HTTP MITM injection risk) removed from `<repositories>` in this PR.

Remaining findings (human follow-up required)

Dependency	CVE	CVSS	Reason not auto-applied
guava 24.1.1-jre	GHSA-7g45-4rm6-3mm3	7.1	MAJOR_REVIEW — fix requires 32.0.0-jre (major jump, potential API changes)
guava 24.1.1-jre	GHSA-5mg8-w23w-74h3	3.3	MAJOR_REVIEW — same upgrade required
mysql-connector-java 8.0.30	CVE-2023-22102	8.3	MAJOR_REVIEW — fix requires <code>com.mysql:mysql-connector-j:8.2.0+</code> (groupId change) + GPL-2.0 license review